

# INGENIERÍA EN COMPUTACIÓN



SEGURIDAD INFORMÁTICA BÁSICA

## EJERCICIO: MODELOS DE SEGURIDAD


**INTEGRANTES**:

CHILPA NAVARRO ALAN SALVADOR- 319207738

MEDINA RUBALCAVA NATALIA MICHELL - 319207336

MURILLO RODRÍGUEZ SARAH SOFIA- 422130448

ORTEGA DE LA PAZ RAFAEL - 420054085

ROMERO GARCÍA DIANA SOFÍA - 319339264


**GRUPO : 2**

**SEMESTRE**: 2027-1

**PROFESORA**: DRA. CINTIA QUEZADA REYES

FECHA: 29 DE OCTUBRE DE 2026

a) **Definición de modelo de seguridad**

Conjunto de principios y reglas que permiten establecer cómo deben protegerse determinados recursos frente a posibles amenazas. Estos modelos sirven para identificar riesgos, definir medidas de protección y establecer las condiciones necesarias para mantener un entorno seguro.

En el ámbito informático, un modelo de seguridad es una representación de las políticas y restricciones que permiten proteger la información y controlar el acceso a los recursos de un sistema. L seguridad de la información se basa principalmente en tres principios fundamentales:

- Confidencialidad: garantiza que únicamente las personas autorizadas puedan consultar información.
- Integridad: asegura que los datos no sean modificados o eliminados sin autorización.
- Disponibilidad: permite que los usuarios autorizados tengan acceso a la información y a los servicios cuando los necesiten.

b) **Definición de modelo concreto y modelo abstracto**

**Modelo Concreto**

Describe las reglas de protección de manera más específica, considerando los usuarios, recursos y operaciones de un sistema determinado. Su propósito es precisar cómo deben aplicarse las políticas de seguridad en un entorno real y facilitar su implementación.

Algunas características son:

- Define permisos y restricciones específicos.
- Considera los componentes del sistema.
- Establece mecanismos para controlar las operaciones.
- Facilita las pruebas de seguridad.
- Permite verificar el cumplimiento de las políticas establecidas.

**Modelo Abstracto**

Es una representación conceptual o matemática que describe las reglas y condiciones que debe cumplir un sistema para considerarse seguro, sin especificar los detalles técnicos de su implementación. Estos modelos permiten analizar el comportamiento de un sistema e identificar posibles problemas de seguridad antes de desarrollar los mecanismos que harán cumplir las reglas.

Algunas características son:

- Define reglas de seguridad.
- Puede utilizar representaciones matemáticas y lógicas.
- No depende de una tecnología específica.
- Permite comprobar propiedades de seguridad.
- Facilita el análisis de posibles vulnerabilidades.

**c) Características de los modelos de control de acceso**

Los modelos de control de acceso son representaciones que establecen qué usuarios o procesos pueden acceder a determinados recursos informáticos y cuáles son las operaciones que tienen permitido realizar. Su objetivo principal es proteger la información mediante reglas de autorización que impiden accesos y modificaciones indebidas.

1. **Modelo de la matriz de acceso**

   Lo propuso Butler Lampson en 1971 y lo refinaron Graham y Denning en 1972. Es la base de casi todo el control de acceso discrecional (DAC).

   El estado de protección es una matriz A con una fila por sujeto y una columna por objeto.

   - S es el conjunto de sujetos y O el de objetos ($S \subseteq O$, porque un sujeto también puede ser accedido).
   - R es el conjunto de derechos (read, write, execute, own…).
   - $A[s, o] \subseteq R$ es el conjunto de derechos que se tiene sobre o.
   - Un sujeto s puede hacer r sobre o si y sólo si $r \in A[s, o$.

   Implementación: la matriz es muy dispersa, así que nunca se guarda completa.

   - ACL (por columnas): cada objeto guarda quién puede hacer qué. Es fácil ver quién accede a un objeto, pero difícil ver todo lo que puede hacer un sujeto.
   - Capacidades (por filas): cada sujeto guarda sus “tickets”. Verificar es rápido, pero revocar es difícil.
   - Tabla de autorización: tuplas (sujeto, derecho, objeto) en una base de datos.

   Reglas de Graham-Denning: son 8 operaciones que modifican la matriz: crear y destruir sujeto, crear y destruir objeto, leer un derecho, otorgarlo (grant), transferirlo (con la marca de copia *) y eliminarlo.

   Características:

   - Es discrecional: el dueño del objeto decide a quién dar acceso.
   - Es simple y general, y permite granularidad fina (par sujeto-objeto).
   - Separa política (la matriz) de mecanismo (ACL o capacidades).
   - Facilita el principio de menor privilegio.
   - Es dinámico, porque los derechos se otorgan y se revocan.

   Limitaciones:

   - No escala si se almacena completa.
   - No tiene tipos, roles ni jerarquías.
   - Es vulnerable a troyanos: un proceso con los derechos de un usuario puede otorgarlos sin que el usuario lo sepa.
   - No responde por sí solo si un derecho puede terminar en manos no autorizadas.

## 2. Modelo HRU

Harrison-Ruzzo-Ullman, 1976. HRU formaliza la matriz de acceso como un sistema de transición de estados, para estudiar una pregunta: ¿Puede un derecho filtrarse a quien no debería tenerlo?

- Un sistema de protección tiene un conjunto finito de derechos R y un conjunto finito de comandos.
- Una configuración es Q = (S, O, P), donde P es la matriz.
- A diferencia de la matriz estática, S y O pueden crecer y decrecer.

Seis operaciones primitivas: *enter r into (s,o), delete r from (s,o), create subject, create object, destroy subject y destroy object.*

Comandos: cada uno tiene condiciones (pruebas de la forma "$r \in P[x,y]$", unidas por AND) y un cuerpo con operaciones primitivas. Por ejemplo:

```
command CONFER_READ(dueño, amigo, archivo)
    if own in P[dueño, archivo] then
    enter read into (amigo, archivo)
end
```

Las 8 reglas de Graham-Denning se pueden escribir como comandos HRU, pero HRU permite además comandos arbitrarios.

Problema de seguridad (safety):

- Un comando filtra (leaks) un derecho r si lo introduce en una celda donde no estaba.
- Una configuración inicial $Q_0$ es insegura para r si existe una secuencia de comandos que lleve a una filtración.

Limitaciones:

- El problema es decidir, dado (sistema, $Q_0$, r), si $Q_0$ es segura para r.
- Es una definición estricta: incluso una concesión legítima del dueño cuenta como fuga.
- El problema de seguridad es indecidible en el caso general. No existe un algoritmo que, para cualquier sistema HRU y cualquier derecho r, decida si r puede filtrarse. Es la limitación principal y el resultado central del artículo de 1976.
- Los casos decidibles son muy restrictivos. El problema solo se puede resolver en clases limitadas, como los sistemas mono-operacionales (una sola operación por comando). Esos sistemas casi no sirven para modelar sistemas reales.
- Expresividad frente a verificabilidad. Al permitir comandos arbitrarios, el modelo es muy expresivo, pero por eso mismo no se puede verificar de forma general. Más poder para describir políticas implica menos capacidad de analizarlas.

- Es un modelo discrecional (DAC). No modela por sí mismo políticas obligatorias (MAC), como niveles de clasificación, ni roles (RBAC).
- No tiene tipos de sujetos y objetos. Todos los sujetos son iguales y todos los objetos son iguales, lo que dificulta modelar políticas realistas y analizarlas. Los modelos con tipos (SPM y TAM) se propusieron después para resolver esto.
- Definición estricta de fuga. Cualquier derecho que aparezca en una celda nueva cuenta como filtración, incluso si fue una concesión legítima del propietario. Para usarlo en la práctica hay que decidir qué sujetos se consideran confiables.

**3. Modelo Take-Grant**

Lo propusieron Jones, Lipton y Snyder en 1976. Es un modelo formal de control de acceso que sirve para analizar cómo se propagan los derechos dentro de un sistema. El estado de protección se representa con un grafo dirigido: los nodos son sujetos u objetos, y las aristas indican los derechos que un nodo tiene sobre otro.

- Los sujetos pueden ser usuarios, procesos o entidades activas.
- Los objetos son recursos pasivos, como archivos, carpetas o dispositivos.
- Los derechos ordinarios pueden ser read, write, execute, own, etc.
- Además, el modelo introduce dos derechos especiales:
    - take (t): permite tomar derechos de otro nodo.
    - grant (g): permite conceder a otro nodo derechos que uno posee.
- Un sistema es seguro si no existe una secuencia de operaciones que permita a un sujeto obtener derechos no autorizados.

Reglas de Take-Grant: son 4 operaciones principales que modifican el grafo:

- **Take:** si un sujeto tiene el derecho *take* sobre otro nodo, puede tomar de él algunos de sus derechos.
- **Grant:** si un sujeto tiene el derecho *grant* sobre otro nodo, puede transferirle derechos que ya posee.
- **Create:** permite crear un nuevo sujeto u objeto.
- **Remove:** permite eliminar un derecho existente entre dos nodos.

Ejemplo: Si A tiene derecho g sobre B, y A tiene permiso de lectura sobre un archivo F, entonces A puede otorgar a B ese permiso de lectura sobre F. Si A tiene derecho t sobre B, A podría tomar un derecho que B tenga sobre otro recurso.

Características:

- Es un modelo formal y matemático, basado en teoría de grafos.
- Permite estudiar la distribución y transferencia de derechos.

- Es dinámico, porque los permisos pueden cambiar con el tiempo.
- Ayuda a responder si un sujeto puede llegar a obtener cierto permiso.
- Es útil para analizar la seguridad de la propagación de privilegios.

Limitaciones:

- Se enfoca en la transferencia de derechos, no en el contenido de la información.
- No modela bien políticas modernas como roles, jerarquías o contextos.
- Puede complicarse cuando el sistema tiene muchos sujetos y objetos.
- No protege por sí mismo contra fugas de información.
- Su uso práctico es más teórico que operativo en sistemas actuales.

**4. Modelo Bell-LaPadula**

Lo propusieron David Bell y Leonard LaPadula en 1973. Es un modelo de seguridad enfocado en la confidencialidad de la información.

Se diseñó para sistemas con información clasificada, como los militares o gubernamentales.

El estado de protección se basa en niveles de seguridad, asignados tanto a los sujetos como a los objetos.

- Cada sujeto tiene una autorización o clearance.
- Cada objeto tiene una clasificación de seguridad.
- Los niveles pueden ser, por ejemplo: Público, Confidencial, Secreto, Alto Secreto.
- El modelo controla el flujo de información para evitar que datos sensibles lleguen a niveles inferiores.
- Es la base del control de acceso obligatorio (MAC).

Reglas de Bell-LaPadula:

- Propiedad de seguridad simple (no read up): Un sujeto no puede leer información de un nivel superior al suyo.
  Ejemplo: un usuario con nivel Confidencial no puede leer un archivo Secreto.
- Propiedad estrella o -property (no write down): Un sujeto no puede escribir información en un nivel inferior al suyo.
  Ejemplo: un usuario con acceso Secreto no puede escribir en un archivo Público.
- Propiedad de seguridad discrecional: Además de cumplir con los niveles de seguridad, el sujeto debe tener los permisos específicos para acceder al objeto.

Ejemplo: Un analista con autorización Secreta puede leer documentos Confidenciales o Secretos, pero no documentos Alto Secreto.

Además, no puede copiar información secreta en un archivo Público, porque eso violaría la propiedad no write down.

Características:

- Está orientado a la protección de la confidencialidad.
- Usa niveles de clasificación bien definidos.
- Restringe el flujo de información entre niveles.
- Es un modelo formal y fácil de aplicar en entornos jerárquicos.
- Es la base de muchos sistemas de seguridad multinivel.

Limitaciones:

- Solo protege principalmente la confidencialidad, no la integridad.
- No evita por sí mismo la modificación indebida de datos.
- Puede ser rígido para entornos donde se necesita compartir información con frecuencia.
- No considera bien situaciones modernas como trabajo colaborativo o sistemas distribuidos complejos.
- Requiere mecanismos adicionales para manejar excepciones y necesidades operativas reales.

**d) Características de los modelos de flujo de información**

Los modelos de flujo de información analizan y rastrean la transferencia de datos entre diferentes entidades (objetos, variables, procesos o dominios de seguridad) a lo largo del tiempo dentro de un sistema informático. A diferencia de los modelos de control de acceso discrecional que solo regulan quién puede abrir o leer un archivo, estos modelos garantizan que la información confidencial no sea divulgada indirectamente o filtrada a través de vías no autorizadas (como canales encubiertos).

Las características principales de los modelos de flujo de información incluyen:

- Estructura de Retículo (Lattice Structure): Se basan principalmente en la teoría de retículos propuesta por Dorothy Denning. El sistema define un conjunto de clases de seguridad ($SC$) ordenadas parcialmente por una relación de flujo ($\leq$), garantizando un límite superior o límite de cota inferior estricto para cada flujo de información.
- Constreñimiento del Flujo de Datos: Regulan no solo el acceso directo a los datos, sino también cómo viajan o se transforman los datos dentro del programa. Se verifica que la información clasificada como clase $A$ solo pueda fluir a una clase $B$ si $A \leq B$.
- Control de Canales Encubiertos: Detectan y mitigan flujos de información implícitos o indeseados (por ejemplo, condicionales if-then-else o variables compartidas del sistema) que podrían transmitir secretos sin violar formalmente una regla de acceso explícita.
- Políticas de Confidencialidad e Integridad: Pueden adaptarse para respaldar tanto la confidencialidad (evitando el flujo hacia niveles inferiores de clasificación) como la

integridad (evitando que datos no confiables o de baja integridad influyan en datos críticos del sistema).

1. **¿Qué es entropía?**
   La Segunda Ley de la Termodinámica dice que todo sistema físico posee una cualidad llamada su entropía, y que mientras un sistema permanezca aislado su entropía no puede disminuir. La entropía (entropía de Shannon) es una medida cuantitativa de la incertidumbre, el desorden o la cantidad de información promedio contenida en una fuente o mensaje de datos. Dependiendo del área de estudio, su definición abarca diferentes perspectivas:

- **Perspectiva General y Física (Termodinámica):** Representa la medida del desorden de un sistema físico y la pérdida de información sobre su estado microscópico. La segunda ley de la termodinámica establece que la entropía de un sistema aislado siempre tiende a aumentar con el tiempo.

- **Perspectiva de la Teoría de la Información (Entropía de Shannon):** Formulada por Claude Shannon, cuantifica la cantidad promedio de incertidumbre o de información contenida en un mensaje, fuente de datos o variable aleatoria.

  Matemáticamente, la entropía $H(X)$ de una variable aleatoria discreta $X$ valores posibles ($X1... x2.... x3... xn$) y probabilidades $P(x_i)$ se define como:

$$H(X) = -\sum_{i=1}^{n} P(x_i)\log_2 P(x_i)$$

**Aplicaciones prácticas del concepto:**

- **Medida de Aleatoriedad y Fuerza Criptográfica:** Representa el grado de impredecibilidad en claves criptográficas, contraseñas y vectores de inicialización (IV). Una mayor entropía indica que la secuencia es más aleatoria y, por ende, más resistente a ataques de fuerza bruta o análisis estadístico.
- **Evaluación de Contraseñas:** Se utiliza para medir la fortaleza real de una contraseña en bits. Por ejemplo, una contraseña de alta entropía utiliza un amplio espacio de caracteres de forma impredecible, complicando la adivinación automatizada.
- **Detección de Malwares y Cifrado:** En el análisis forense y de software malicioso, la alta entropía en secciones de un archivo ejecutable suele indicar que el código está comprimido, empaquetado (*packed*) o cifrado, comportamiento habitual en el *ransomware* y troyanos para evadir antivirus.

- **Cuantificación de Fugas de Información:** En los modelos de flujo de información, la entropía condicional y la información mutua se utilizan para cuantificar cuánta información sobre un secreto se filtra al observar el comportamiento externo o el tiempo de ejecución de un programa.

**e) Características de los modelos de integridad**

Los modelos de integridad son modelos formales de seguridad cuyo objetivo es evitar que la información sea modificada de forma indebida. A diferencia de Bell-LaPadula, que controla quién puede leer la información, estos modelos controlan quién puede escribirla o alterarla.

Características principales:

- Se enfocan en la integridad, no en la confidencialidad.
- Evitan que usuarios no autorizados modifiquen la información y que usuarios autorizados
- hagan cambios indebidos.
- Mantienen la consistencia de los datos (lo que dice el sistema corresponde con la realidad).
- Impiden que datos o programas poco confiables influyan en datos críticos.
- Pueden basarse en niveles de integridad (Biba) o en transacciones controladas (Clark-
- Wilson).

**1.- Modelo Biba**

Lo propuso Kenneth J. Biba en 1975, en la MITRE Corporation (Biba, 1975). Es un modelo enfocado en la integridad de la información y se considera el inverso de Bell-LaPadula: usa niveles, pero invierte las reglas para evitar que la información se contamine.

- Cada sujeto y cada objeto tiene un nivel de integridad, que indica qué tan confiable es.
- Los niveles pueden ser, por ejemplo: Bajo, Medio, Alto y Sistema.
- La información solo puede fluir de los niveles más confiables a los menos confiables.
- Es un modelo de control de acceso obligatorio (MAC).

Reglas de Biba:

- **Propiedad de integridad simple (no read down):** un sujeto no puede leer información de un nivel de integridad inferior al suyo.
- Ejemplo: un proceso del sistema no debe tomar como entrada un archivo descargado de internet.
- **Propiedad estrella de integridad (no write up):** un sujeto no puede escribir en un objeto de nivel de integridad superior al suyo.
- Ejemplo: un usuario común no puede modificar los archivos de configuración del sistema operativo.
- **Propiedad de invocación:** un sujeto no puede solicitar servicios a un sujeto de nivel superior.

Ejemplo: Windows aplica este principio con su Mandatory Integrity Control: un proceso de integridad baja no puede escribir en un objeto de integridad media, aunque sus permisos se lo permitan (Microsoft, 2025).
Características:

- Está orientado a la protección de la integridad.
- Usa niveles jerárquicos de integridad para sujetos y objetos.
- Es un modelo formal y obligatorio: el sistema impone las reglas.
- Es simple de aplicar, porque solo compara niveles.
- Evita que datos poco confiables contaminen datos críticos.

Limitaciones:

- No protege la confidencialidad.
- Sus reglas son opuestas a las de Bell-LaPadula, por lo que es difícil usar ambos a la vez.
- Es rígido: muchos procesos necesitan leer datos de entrada poco confiables.
- No evita que un usuario autorizado haga cambios incorrectos o fraudulentos.
- No contempla separación de funciones ni auditoría.

**2- Modelo de Clark-Wilson**

Lo propusieron David D. Clark y David R. Wilson en 1987 (Clark & Wilson, 1987). Está pensado para entornos comerciales, como bancos y sistemas contables, donde lo más importante es evitar el fraude y los errores. En lugar de niveles, se basa en dos principios: transacciones bien formadas y separación de funciones.

- **CDI** (Constrained Data Item): datos cuya integridad se debe proteger, como el saldo de una cuenta.
- **UDI** (Unconstrained Data Item): datos de entrada no verificados, como lo que escribe un usuario.
- **TP** (Transformation Procedure): programas autorizados que modifican los CDI.
- **IVP** (Integrity Verification Procedure): procedimientos que verifican que los CDI sean válidos.

Reglas de Clark-Wilson:

- **Reglas de certificación:** los TP y los IVP deben ser revisados y aprobados antes de usarse; cada TP debe llevar los datos de un estado válido a otro, registrar sus operaciones en una bitácora y validar o rechazar los datos de entrada (UDI).
- **Reglas de aplicación:** el sistema solo permite modificar los CDI mediante TP certificados, autentica a cada usuario y solo permite las combinaciones usuario–programa–dato autorizadas.
- **Separación de funciones:** quien certifica una operación no puede ser quien la ejecuta.

Ejemplo: en un banco, el cliente no puede cambiar su saldo directamente; solo puede usar la

operación «retiro», que valida el monto, actualiza el saldo y registra el movimiento. Al final del día se verifica que los saldos coincidan con los movimientos.

Características:

- Está orientado a la integridad en entornos comerciales.
- Los usuarios solo acceden a los datos por medio de programas autorizados.
- Se basa en transacciones bien formadas y separación de funciones.
- Incluye auditoría mediante bitácoras.
- Protege también contra cambios indebidos de usuarios autorizados.

Limitaciones:

- La certificación depende de personas y no se puede automatizar por completo.
- Certificar cada programa es costoso en sistemas grandes o que cambian con frecuencia.
- Es menos formal y matemático que Biba o Bell-LaPadula.
- No protege la confidencialidad.
- Si un programa se certificó mal, el modelo no lo detecta por sí mismo.

**Referencias**


Berti, J. (2026, 1 de julio). *Discover the 6 information security models: Biba, Bell-LaPadula & more*. Destination Certification. https://destcert.com/resources/information-security-models/

Biba, K. J. (1975, 30 de junio). Integrity considerations for secure computer systems (MTR-3153). The MITRE Corporation. Recuperado el 29 de octubre de 2026, de https://seclab.cs.ucdavis.edu/projects/history/papers/biba75.pdf

Calzetta, E. (s. f.). *Entropía*. Instituto Nacional de Educación Tecnológica (INET). https://www.inet.edu.ar/index.php/material-de-capacitacion/nueva-serie-de-libros/entropia/

Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. En 1987 IEEE Symposium on Security and Privacy (p. 184). IEEE. Recuperado el 29 de octubre de 2026, de https://doi.org/10.1109/SP.1987.10001

Hu, V. C., Kuhn, D. R., & Yaga, D. J. (2017). *Verification and test methods for access control policies/models (NIST Special Publication 800-192)*. National Institute of Standards and Technology. Recuperado el 29 de octubre de 2026, de https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-192.pdf

Microsoft. (2025, 8 de julio). Control de integridad obligatorio. Microsoft Learn. Recuperado el 29 de octubre de 2026, de https://learn.microsoft.com/es-es/windows/win32/secauthz/mandatory-integrity-control

Mizrachi, A. (2026, 20 de julio). *Access control matrix: Key components and 5 critical best practices*. Frontegg. https://frontegg.com/blog/access-control-matrix

Nieles, M., Dempsey, K., & Pillitteri, V. Y. (2017). *An introduction to information security (NIST Special Publication 800-12, Revision 1)*. National Institute of Standards and Technology. Recuperado el 29 de octubre de 2026, de https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf

Shannon, C. E. (1948). *A mathematical theory of communication.* The Bell System Technical Journal, 27(3), 379–423. https://doi.org/10.1002/j.1538-7305.1948.tb01338.x

Silva Forné, C. (2015). *Modelos de seguridad, prácticas violatorias de derechos humanos y opinión pública*. Comisión de Derechos Humanos del Distrito Federal. Recuperado el 29 de octubre de 2026, de https://archivos.juridicas.unam.mx/www/bjv/libros/14/6652/6.pdf

Valente, A. (2003). *Un servidor de aplicaciones MLS: especificación y verificación de propiedades de seguridad* [Tesis de licenciatura, Universidad Nacional de La Plata]. SEDICI. https://sedici.unlp.edu.ar/handle/10915/3902